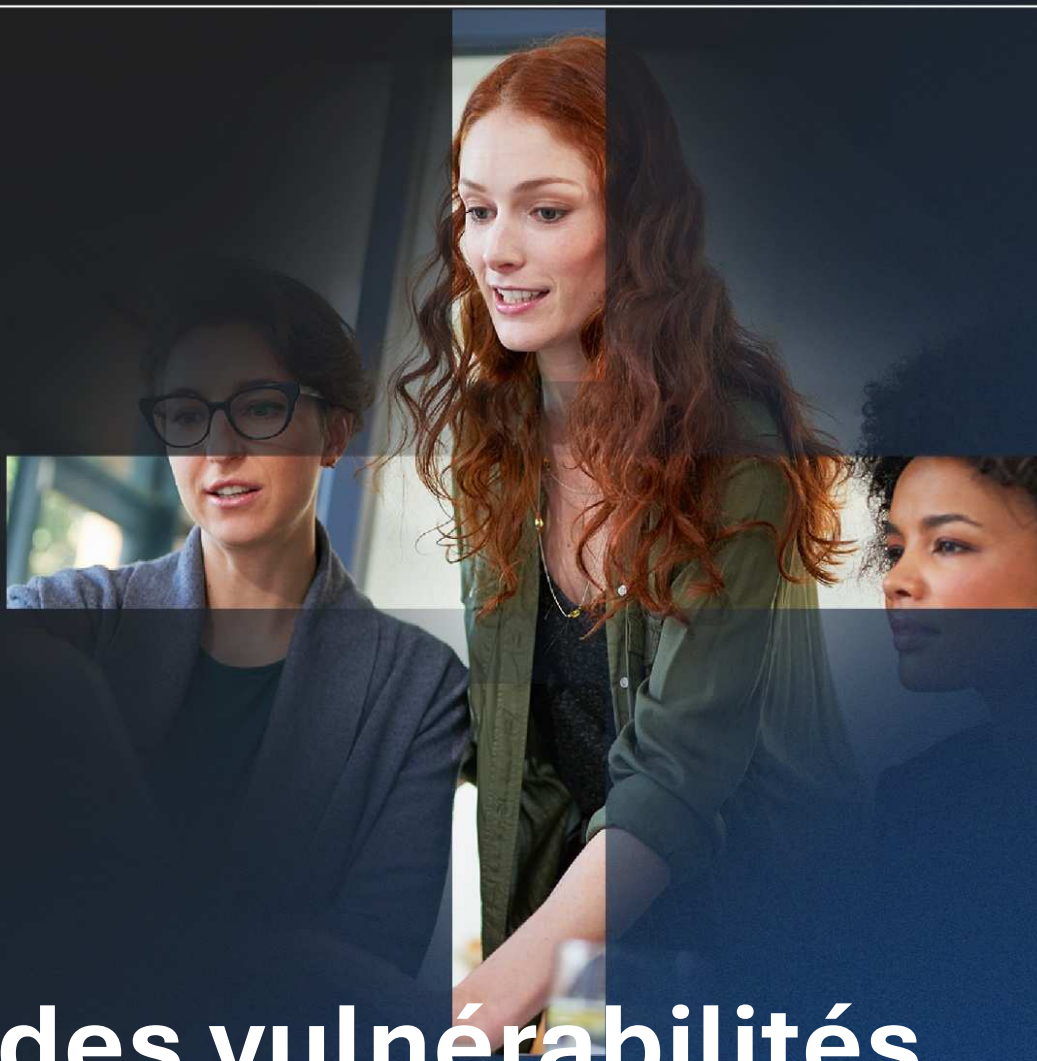




Gestion des vulnérabilités critiques

Méthodologie de réponse à incident

2025-10-31 | **IRM-21**

CERT aDvens - CSIRT

Advens - 38 rue des Jeuneurs - 75002 Paris

SOMMAIRE

Introduction 2

Étapes de traitement des incidents 3

1. Préparation 4

2. Identification 5

3. Confinement 6

4. Remédiation 7

5. Récupération 8

6. Capitalisation et apprentissage 9

INTRODUCTION

Cette méthodologie de gestion des vulnérabilités (*VMM - Vulnerability Management Methodology*) est un guide concis destiné aux professionnels chargés de gérer et de traiter les vulnérabilités de sécurité spécifiques au sein d'une organisation.

→ Cette fiche IRM s'adresse aux personnes ou fonctions suivantes :

- Administrateurs système
- Équipes du centre des opérations de sécurité
- RSSI et leurs adjoints
- Équipes de gestion des vulnérabilités
- Équipes d'intervention en cas d'urgence informatique

Rappels importants :

Suivre l'IRM : Respecter la méthodologie établie afin de garantir une approche structurée et efficace de la gestion des vulnérabilités.

Documenter de manière rigoureuse : Conserver des notes détaillées sur les constats, les actions menées et les décisions prises lors de l'évaluation et de la remédiation des vulnérabilités.

Rester calme: Adopter une approche rigoureuse, sereine et méthodique lors de l'identification et du traitement des vulnérabilités.

Agir de façon appropriée : Contacter immédiatement l'équipe de gestion des vulnérabilités ou le CERT de votre organisation en cas d'assistance ou d'escalade.

→ [IRM CERT-SG](#)

→ [IRM CERT-aDvens](#)

En utilisant les fiches méthodologiques de gestion des vulnérabilités, les organisations peuvent garantir une approche cohérente et efficace pour identifier, hiérarchiser et corriger les vulnérabilités. Cette méthodologie structurée soutient la protection des actifs critiques et renforce la posture de sécurité globale.

ÉTAPES DE TRAITEMENT DES INCIDENTS

6 étapes sont définies pour gérer les incidents de sécurité :

1. **Préparation** : Se préparer à gérer l'incident,
2. **Identification** : Détecter l'incident,
3. **Confinement** : Limiter l'impact de l'incident,
4. **Remédiation** : Supprimer la menace,
5. **Récupération** : Revenir à un état normal,
6. **Capitalisation et apprentissage** : Élaborer et améliorer les processus.

Cette IRM fournit des informations détaillées pour chaque étape du processus de réponse aux incidents. Les étapes sont issues du [NIST Computer Security Incident Handling Guide](#).

OBJECTIFS :

Améliorer la gestion de la vulnérabilité

Améliorer l'identification et la priorisation des vulnérabilités grâce au renseignement sur les cybermenaces.

Optimiser l'allocation des ressources

Veiller à ce qu'un minimum de ressources soit mobilisé sur les vulnérabilités les plus critiques.

Renforcer la réponse aux incidents

Intégrer le renseignement sur les cybermenaces dans la réponse à incidents pour fournir un contexte et des capacités décisionnelles exploitables lors du traitement de l'incident.

Réduire l'exposition aux risques

Réduire au minimum la surface d'attaque en traitant de manière proactive les vulnérabilités à haut risque.

1. PRÉPARATION

Objectifs : Établir des contacts, définir des procédures et collecter des informations pour gagner du temps lors d'un incident.

- Développer ou acquérir des sources d'informations issues de la Cyber Threat Intelligence (CTI) sur les vulnérabilités et les exploits, telles que les flux de menaces, les rapports de renseignement, des dépôts et des bases de données spécialisées.
- Mettre en place des outils et des plateformes internes de surveillance de la vulnérabilité et de CTI pour l'agrégation et l'analyse des données.
- Assigner des responsabilités pour la collecte, l'analyse et l'intégration de la CTI dans la gestion des vulnérabilités.
- Créer des procédures de référence pour évaluer et prioriser les vulnérabilités à l'aide de la CTI.
- Dresser un inventaire complet de tous les systèmes et de toutes les versions de logiciel au sein de l'organisation afin de comprendre la surface d'attaque potentielle.
- Établir un programme de veille sur les menaces afin de collecter et analyser en continu les informations sur les menaces et vulnérabilités émergentes.
- Préparer des canaux de communication et des modèles de messages pour diffuser rapidement les informations nécessaires lors d'un incident lié à une vulnérabilité.
- Former l'équipe de réponse à incidents et les autres équipes concernées, à l'utilisation d'outils, de services et de méthodologies de veille sur les menaces et la surveillance des vulnérabilités.
- Mettre en place des canaux opérationnels pour un partage d'informations efficace entre les équipes impliquées.

Sensibilisation des parties prenantes à la gestion proactive des vulnérabilités

La gestion proactive des vulnérabilités est essentielle afin de protéger les systèmes d'information de l'entreprise. Plutôt que d'attendre qu'une faille soit exploitée, communiquer sur l'importance de la gestion des vulnérabilités au sein de l'organisation.

Mettre en avant des cas concrets pour illustrer les impacts potentiels sur l'activité et la production, et pour souligner l'enjeu d'un traitement rapide des vulnérabilités. Expliquer aux parties prenantes ce qu'implique la gestion des vulnérabilités et s'assurer qu'elles comprennent les risques et les bénéfices qui y sont associés.

Indiquer clairement que les parties prenantes peuvent demander de l'aide et de l'assistance en cas de besoin. Grâce à une sensibilisation efficace et à une communication ouverte, donner aux équipes en place les moyens de mieux protéger les actifs et les systèmes d'information de l'organisation.

2. IDENTIFICATION

Objectifs : Détecter l'incident, déterminer sa portée et impliquer les parties concernées.

Analyse de la vulnérabilité

- Utiliser des outils automatisés pour identifier les vulnérabilités des systèmes et des applications.

Collecte de données de CTI

- Collecter des renseignements issus de multiples sources CTI, incluant les sources ouvertes, les flux commerciaux et les centres de partage et d'analyse d'informations, tels que les ISAC.

Profilage des acteurs de la menace

- Identifier les acteurs malveillants potentiels, en fonction du secteur d'activité et de la technologie de l'organisation.

Évaluation des vulnérabilités

- Évaluer la gravité des vulnérabilités identifiées à l'aide de normes telles que CVSS, EPSS, etc.

Intégration de la CTI

- Corréler les vulnérabilités avec les renseignements CTI afin de déterminer si elles sont activement exploitées ou ciblées par des acteurs malveillants.

Analyse environnementale

- Évaluer la pertinence de chaque vulnérabilité en fonction du contexte propre à l'organisation et la réalité des menaces.

Priorisation

- Déterminer l'impact potentiel et la probabilité d'exploitation de chaque vulnérabilité.
- Appliquer des scores issus de la CTI aux vulnérabilités, en fonction de facteurs tels que la disponibilité des exploits, l'activité des acteurs malveillants et le ciblage industriel.
- Créer des workflows basés sur une logique ou des scores afin de classer les vulnérabilités par niveau de priorité (par exemple : très élevé, élevé, moyen, faible), en se fondant sur le risque global et les indicateurs CTI.
- Intégrer un niveau de criticité métier et l'impact potentiel sur l'activité et la production lors de la priorisation des vulnérabilités dans votre organisation.

Normes et outils de priorisation

Le CVSS se concentre sur la gravité des vulnérabilités en fonction de leurs caractéristiques techniques, mais manque de données sur l'exploitabilité en conditions réelles.

L'EPSS prédit la probabilité d'une exploitation, offrant ainsi une approche plus dynamique et exploitable pour la priorisation.

Les outils de gestion du risque de vulnérabilité combinent souvent les scores CVSS et EPSS avec un contexte organisationnel ou environnemental, tel que la criticité des actifs ou l'impact métier.

Les éditeurs et les organisations développent souvent leurs propres modèles et systèmes de notation, adaptés à leur tolérance au risque et à leurs besoins opérationnels.

3. CONFINEMENT

Objectif : Atténuer les effets de l'attaque sur l'environnement ciblé.

- Élaborer des plans d'action pour traiter en priorité les vulnérabilités les plus critiques, en s'appuyant sur la gestion des correctifs, des modifications de configuration ou d'autres stratégies d'atténuation.
- Définir des délais contraints et des accords de niveau de service (SLA - *Service Level Agreement*) adaptés aux différents niveaux de sévérité des vulnérabilités.
- Allouer efficacement les ressources afin d'assurer une remédiation rapide des vulnérabilités critiques.
- Informer les parties prenantes concernées des vulnérabilités prioritaires et des plans de remédiation.

Un accord de niveau de service (SLA - *Service Level Agreement*) en gestion des vulnérabilités est un accord formel qui définit les attentes, les délais et les responsabilités pour le traitement des vulnérabilités de sécurité. Il est essentiel pour garantir que les vulnérabilités soient corrigées en temps voulu et de manière efficace, réduisant ainsi le risque d'exploitation en s'alignant sur les objectifs de sécurité de l'organisation.

Les SLA fixent des délais précis pour la correction des vulnérabilités en fonction de leur gravité.

Par exemple, les vulnérabilités critiques doivent être corrigées dans un délai de 24 à 72 heures, tandis que celle à faible risque peuvent être traitées dans des délais plus longs. Ces délais garantissent que les risques les plus graves sont traités en priorité et rapidement atténués.

Les SLA doivent être alignés sur l'appétence au risque de l'organisation et sur l'impact potentiel des vulnérabilités.

Ainsi, les vulnérabilités critiques susceptibles de provoquer des incidents majeurs, des fuites de données ou des interruptions de service sont traitées plus rapidement que les vulnérabilités mineures.

4. REMÉDIATION

Objectif : Prendre des mesures pour éliminer la menace et prévenir de nouveaux incidents.

Planification de la remédiation

- Élaborer des plans d'action pour traiter en priorité les vulnérabilités les plus critiques, en s'appuyant sur la gestion des correctifs, des modifications de configuration ou d'autres stratégies d'atténuation.

Allocation des ressources

- Allouer efficacement des ressources pour garantir une correction rapide des vulnérabilités critiques.

Communication

- Informer les parties prenantes concernées sur les vulnérabilités prioritaires et les plans de remédiation.

Mettre en place des mécanismes de sauvegarde et de restauration

- Faire des sauvegardes du système avant d'appliquer des correctifs ou d'effectuer des changements ; s'assurer que les systèmes ou les applications sont sauvegardés pour permettre une restauration en cas de problèmes inattendus.
- Élaborer des plans et des procédures de restauration afin de pouvoir rétablir rapidement l'état initial en cas de perturbation ou d'inefficacité des actions de remédiation,

Faire des tests préalables à la remédiation

- Appliquer des correctifs ou des changements de configuration dans un environnement de test ou de type bac à sable afin d'évaluer leur impact avant de les déployer en production.
- Évaluer proactivement la compatibilité pour s'assurer que les actions de remédiation n'affectent pas négativement les performances, la fonctionnalité ou la compatibilité du système avec d'autres applications.

Systèmes intégrés de remédiation et outils de suivi

En mettant en place des outils de remédiation et de suivi, les organisations peuvent transformer la gestion cyclique des vulnérabilités en un programme d'amélioration continue, renforçant significativement la posture de sécurité tout en maintenant l'intégrité opérationnelle dans des environnements complexes.

Les outils de suivi de la remédiation sont des solutions dédiées permettant de suivre, vérifier et mesurer l'efficacité des actions de remédiation des vulnérabilités au sein de l'organisation.

Ces outils comblent l'écart entre la gestion des vulnérabilités et la gestion des correctifs en offrant une visibilité continue sur l'avancement des remédiations et en vérifiant que les failles de sécurité sont réellement corrigées. Lorsqu'ils sont correctement mis en place, ces systèmes créent une responsabilisation, une visibilité mesurable via des KPI dynamiques et garantissent qu'aucune vulnérabilité ne demeure non traitée après les premières tentatives de remédiation.

De la même manière, les tableaux de bord de remédiation à l'échelle de l'entreprise offrent aux équipes de sécurité et à la direction une visibilité en temps réel sur l'état d'avancement des remédiations, les délais et leur efficacité. Ces plateformes agrègent les données issues de différents outils de sécurité pour fournir une vue unifiée de l'état d'avancement des corrections, en cohérence avec les SLA définis et les seuils de risque.

5. RÉCUPÉRATION

Objectif : Restaurer le fonctionnement normal du système.

Mettre en œuvre des actions de remédiation

- Pour les environnements de grande envergure, envisager un déploiement progressif des actions de remédiation pour surveiller les éventuels dysfonctionnements et de réduire les risques, selon la structure organisationnelle et l'architecture en place,
- Utiliser des outils d'automatisation de tâches pour le déploiement de correctifs, les changements de configuration ou les mises à jour de code afin de rationaliser le processus de remédiation et de réduire les erreurs autant que possible.

Valider l'efficacité de la remédiation

- Réaliser des tests post-remédiation pour confirmer que la vulnérabilité a été entièrement corrigée sans générer de nouveaux problèmes de sécurité ou de fonctionnalité.
- Utiliser des outils de scan de vulnérabilités après remédiation afin de s'assurer que les problèmes précédemment identifiés n'existent plus.

Documentation et indicateurs

- Consigner toutes les activités de remédiation, avec les actions entreprises et leurs résultats respectifs.
- Suivre des indicateurs clés de performance afin d'évaluer l'efficacité du processus.

Processus et services post-remédiation

Les processus de post-médiation efficaces intègrent des tests de vérification qui confirment que les vulnérabilités sont réellement corrigées et non traitées superficiellement.

Le Threat Hunting (recherche active de menaces) peut être intégré dans un contexte de post-remédiation comme une approche de sécurité proactive allant au-delà des scans de vulnérabilités classiques pour rechercher activement d'éventuels signes d'activité malveillante survenus durant la période d'exposition de la vulnérabilité. Le Threat Hunting constitue ainsi une couche essentielle de vérification, garantissant la sécurité continue des environnements après les actions correctives. Il repose sur des techniques avancées de détection, telles que l'analyse comportementale, la détection d'anomalies et la reconnaissance de motifs, afin d'identifier des indicateurs de compromission susceptibles d'échapper aux scanners traditionnels. Par exemple, même si une vulnérabilité RCE critique a été corrigée, le Threat Hunting peut déterminer si elle a été exploitée avant la correction en analysant les journaux systèmes, le trafic réseau et les variations d'intégrité des fichiers.

Le processus de gestion de la surface d'attaque ou ASM (Attack Surface Management) offre une visibilité continue sur les surfaces d'attaque internes et externes d'une organisation, permettant aux équipes de sécurité de mieux appréhender le contexte et l'impact potentiel des vulnérabilités à l'échelle de l'entreprise.

L'ASM complète la gestion classique des vulnérabilités en fournissant des informations en temps réel sur le niveau d'exposition, même après les actions de remédiation. Les services ASM procèdent à un inventaire permanent des actifs, surveillent les changements de surface d'attaque et hiérarchisent les priorités selon le contexte métier et le renseignement sur la menace.

Par exemple, après la correction d'une vulnérabilité critique sur une application publique, l'ASM peut vérifier la bonne application du correctif sur l'ensemble des instances et signaler tout nouveau déploiement susceptible de réintroduire la faille.

6. CAPITALISATION ET APPRENTISSAGE

Objectif : Améliorer les futurs processus de réponse à incident et de gestion des vulnérabilités.

- Analyser l'efficacité des processus de priorisation et de remédiation des vulnérabilités.
- Intégrer les enseignements issus de l'analyse dans les processus CTI et IRM pour améliorer la gestion des vulnérabilités à venir.
- Mettre à jour les politiques, les procédures et les outils en fonction des enseignements tirés afin de renforcer l'ensemble du cycle de gestion des vulnérabilités.
- Effectuer un retour d'expérience post-incident afin d'évaluer l'efficacité de la réponse et d'identifier les domaines à améliorer.
- Actualiser les processus de renseignement sur les menaces et de gestion des vulnérabilités en fonction des enseignements tirés.
- Partager les informations et retours d'expérience avec les acteurs concernés afin de renforcer la sensibilisation et la préparation de l'organisation.
- Rédiger un rapport détaillé de l'incident, incluant les vulnérabilités identifiées, les actions mises en œuvre et les résultats obtenus.
- Utiliser la CTI pour fournir un contexte et une analyse de l'incident, en mettant en évidence les tendances et les schémas récurrents.
- Diffuser le rapport aux acteurs clés et l'utiliser afin d'alimenter les futures stratégies de renseignement sur les menaces et de réponse à incident.

Maintien des connaissances et amélioration continue

La gestion des connaissances dans la réponse aux vulnérabilités constitue un pilier essentiel pour renforcer la résilience organisationnelle et prévenir la récurrence d'exploitations réussies. Les connaissances précieuses se retrouvent souvent enfermées dans des environnements isolés, empêchant un véritable apprentissage organisationnel et entraînant la répétition des erreurs de sécurité. Une gestion efficace des connaissances transforme les expériences individuelles en savoir organisationnel en consignait systématiquement les approches de remédiation, les stratégies d'atténuation (mitigation) et les processus de décision qui ont fonctionné - ou non - lors d'incidents de sécurité.

La collecte et l'analyse systématiques des enseignements tirés pendant une remédiation des vulnérabilités créent une boucle de rétroaction qui renforce continuellement la posture de sécurité de l'organisation. En documentant les incidents évités de justesse, les mesures d'atténuation réussies et les difficultés liées à la remédiation, les équipes de sécurité bâtissent une mémoire institutionnelle qui gagne en valeur au fil du temps. Ce référentiel de connaissances permet aux organisations de valoriser les incidents de sécurité évités, de quantifier les "non-événements" correspondant à des actions préventives réussies, et de démontrer auprès de la direction, la valeur ajoutée des investissements en sécurité et les efforts de remédiation proactive.